Standard Operating Procedure: Cyber Incident Handling Playbook

Framework: NIST SP 800-61 Rev. 2 | Version 3.4 | Classification: Corporate Internal

1. Purpose & Guiding Principles

This procedure establishes standardized protocols for triage, investigation, containment, eradication, and post-incident recovery across all enterprise information systems. The primary goals are minimizing operational disruption, protecting customer privacy, and maintaining complete forensic chain of custody for legal and regulatory compliance.

Core Incident Response Lifecycle Phases: Phase 1: Preparation & Tooling Readiness Phase 2: Detection, Triage & Comprehensive Analysis Phase 3: Containment, Eradication & System Recovery Phase 4: Post-Incident Activity & Lessons Learned

2. Severity Classification Matrix

Severity Level	Response SLA	Escalation Authority	Communication Protocol
Critical (P1)	15 Minutes	Chief Information Security Officer (CISO)	Hourly Executive War Room Briefings
High (P2)	30 Minutes	SOC Operations Manager	Bi-Hourly Leadership Email Notifications
Medium (P3)	2 Hours	Lead Incident Responder	Standard Ticketing System Updates
Low / Informational	8 Hours	SOC Tier-1 Analyst	Daily Shift Handover Report

3. Forensic Evidence Collection & Chain of Custody

When responding to potential endpoint intrusions, analysts must strictly adhere to the Order of Volatility (RFC 3227):

• **Volatile Memory Capture**: Collect full RAM dumps using enterprise EDR live response or LiME before powering down hosts.

• **Network Connection State**: Record established TCP/UDP sockets, ARP cache, and active listening services.

• **Disk Imaging**: Create bit-stream disk images using write-blocking hardware, computing SHA-256 integrity hashes immediately upon acquisition.

• **Audit Logging**: Forward SIEM syslog records and EDR telemetry to write-once-read-many (WORM) compliant long-term storage.

4. Post-Incident Review Protocol

Within 72 hours of incident closure, the incident commander shall facilitate a blameless post-mortem retrospective. Key deliverables include root cause determination, timeline verification, preventive security recommendations, and updating threat detection signatures.

5. Emergency Contact Roster

The following verified internal channels are authorized for incident communications:

Role	Designee	Secure Contact Channel	Secondary Channel
Incident Commander	SOC Lead On-Call	soc-commander@enterprise.example.com	Signal Bridge #1
Legal Counsel	Cyber Privacy Team	legal-compliance@enterprise.example.com	Office Direct Desk
Communications Lead	Corporate Media Desk	press-relations@enterprise.example.com	Cellular Phone
Infrastructure Liaison	Cloud Engineering Lead	cloud-ops@enterprise.example.com	PagerDuty High Priority

Classification: BENIGN / SAFE (No indicators detected)